(1) Introduction

This report shows the analysis the comprehensive analysis of the infected Cobalt Strike attack system based on the pcap file (traffic logs). The goal is to identify the infected system and how it is being attacked.
Section (2) talks about what tools used and how to perform the intrusion analysis.
Section (3) describe the results and evidence.
Section (4) summarize the whole analysis.
Section (5) shows the reference materials.

(2) Methodology

To reconstruct the sequence of events, I need to know the what, who, when, what, how.

The pcap file contains all the transaction logs. The Wireshark software is capable of finding every detail information about every packets in the infected system by “Follow TCP stream”, or by filtering in the display searching field, or by finding the statistics data.

Before diving into the details, “Zui” software is used to get a general idea of what is happening (it summarize the activities) and how it is happening. To trace how the system got infected, I filtered the alert events. (As shown in Fig1, searching : event_type=="alert" | fuse | sort ts). And then I export to an excel file—ZUI-ALERT.csv and placed in the folder “ZUI-ALERT” in github. (“ET” in the alert messages means emerging threats)

Fig1
As such, in order to view detail information (e.g. MAC address, hostname, domain), click the "Wireshark" button in Zui, and then switch between Zui and Wireshark.

Then, to indicate the infection, I use “VirusTotal” website to check whether IP or URL is malicious. (As Fig 2 below)

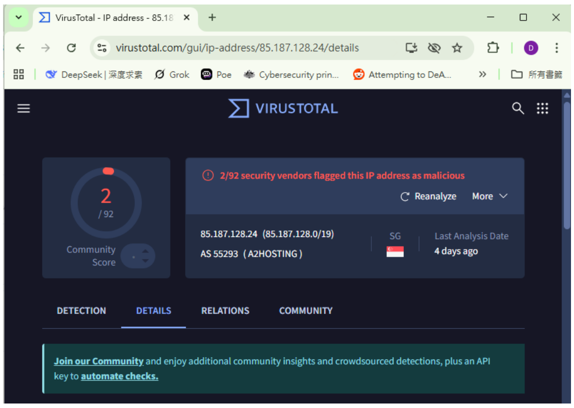


Fig 2

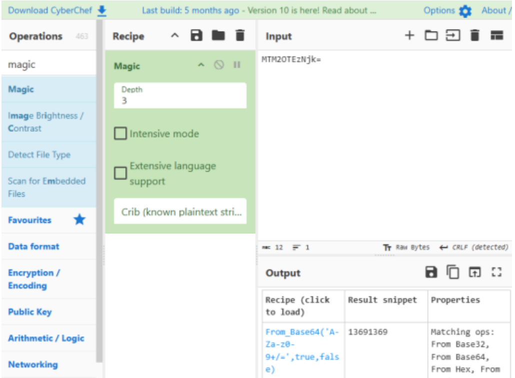


Fig3

Other tools like CyberChef is used to check the information hidden in the “garbled text”. (As Fig3 above) Windows Terminal is used to check the name of the file located in the compressed file (As Fig 4 below).

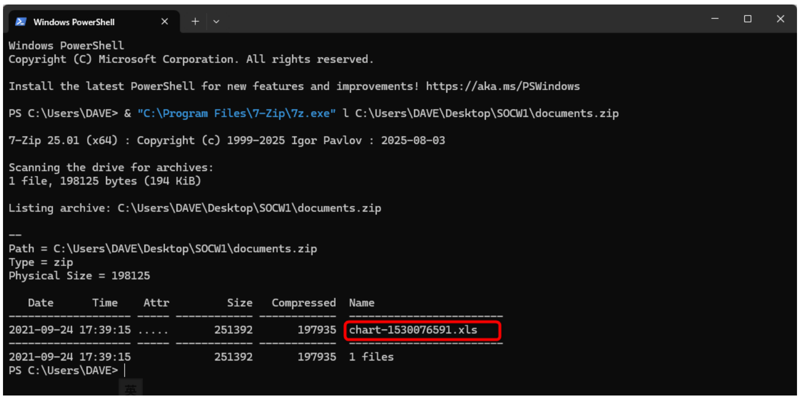


Fig 4

(3) Results

General Understanding:

From the question set, it is known that this is a “Cobalt Strike Attack”. Normally, the victim will send packets to the hacker server to show that “I am alive”. By investigating the ZUI-ALERT.csv (as state in Section 2), this “Cobalt Strike Attack” is broadly divided into four stages.

Phrase 1: Initial Infection (16:44-16:53)

The alert “ET MALWARE SQUIRRELWAFFLE Loader Activity (POST)” (Fig 5) means that the victims (10.9.23.102) is sending the packets to the hacker server (281.91.128.6). According to the alert, 281.91.128.6 is loading server. It will keep on loading malware or virus to the 10.9.23.102.

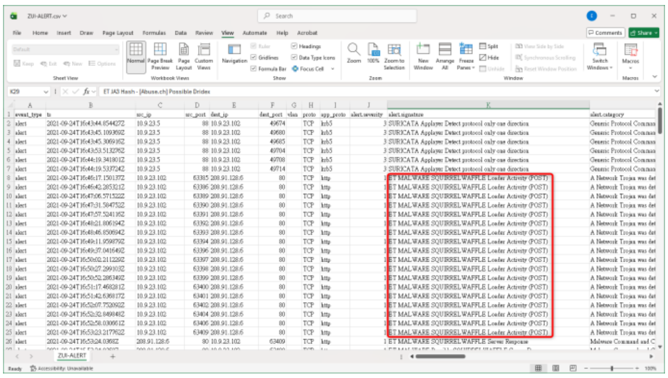


Fig 5

Phrase 2: Second-stage infection (16:53 – 17:00)

The alert shows:” ET JA3 Hash - [Abuse.ch] Possible Dridex”. That is, the victim is infected by Dridex. Dridex is Botnet. Dridex is loaded by SQUIRRELWAFFLE.

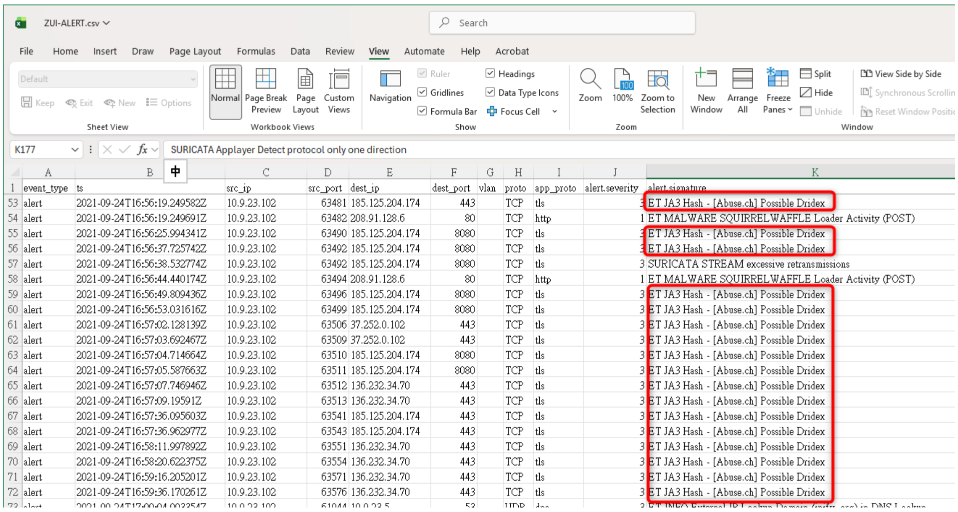


Fig 6

Phrase 3: Reconnaissance (17:00 -17:02)

The alert shows:” ET INFO External IP Lookup Domain (ipify .org) ”. The victim is asking ipify.org : what is the external IP of me. The malware needed this information to confirm the victim status and then report to C2 server later.

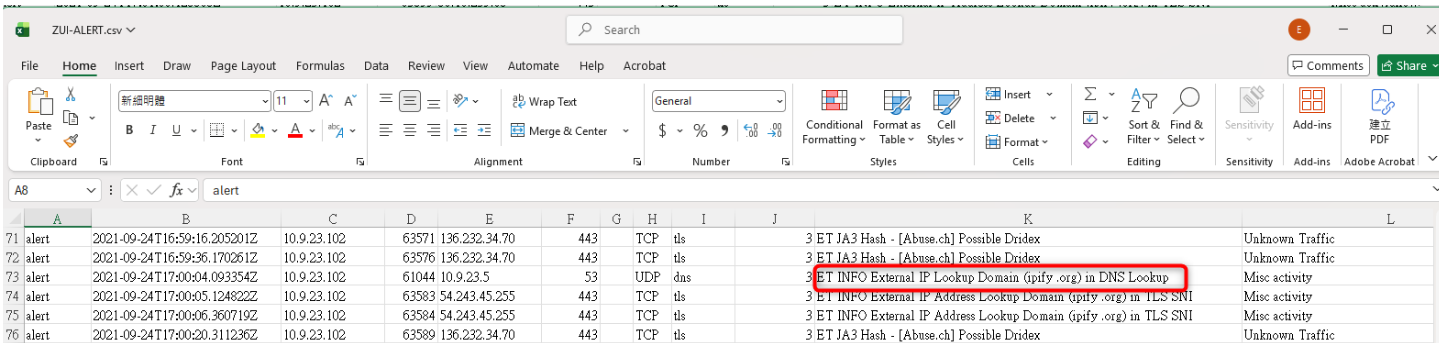


Fig 7

Phrase 4: Diffusion (17:02 onwards)

The victim becomes zombie and send the spam email (SMTP protocol) through port 25. (Fig7). The alert is “SURICATA Applayer Detect protocol only one direction”

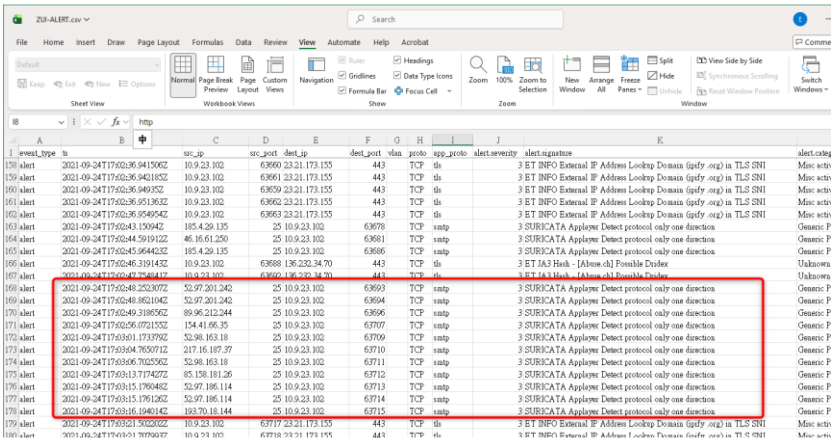


Fig 8

The roles of this Cobalt Strike attack infer with evidence as follow (will further explain):

C2 Server : 185.125.204.174 (Cobalt strike C2), 185.106.96.158(Cobalt strike C2), 281.91.128.6 (loader C2)

Victim : 10.9.23.102

Spy : 185.125.204.174, 136.232.34.70 (JA3 is the sign)

Qbot : 85.187.128.24 (IP in Q3)

Zombie : 10.9.23.102 (send spam emails to other IP)

Staging Server : 208.91.128.6

With above general understanding, let's further investigate in details with reference to the question set provided in advance.

Phrase 1 in the question set (Q1 - 8, Q13 -16.):

The initial malicious HTTP connection occur at 2021–09–24 16:44:38 (searching "http" in Wireshark as Fig SO_CW1_Q1 below). More precisely, it is the first handshake (SYN) of the TCP three way handshake.

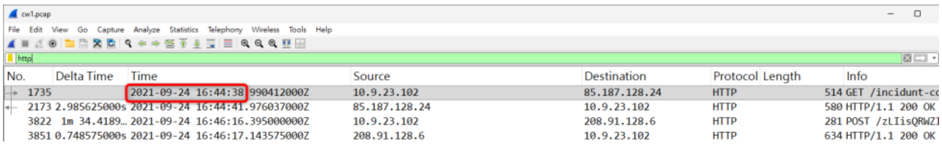


Fig SO_CW1_Q1

The name of the compressed file that the victim downloaded is "documents.zip" (by searching in Zui as shown in Fig SO_CW1_Q2)

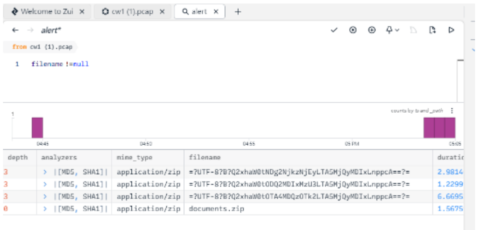


Fig SO_CW1_Q2

The domain hosted the malicious compressed file is found by searching in Zui (Fig SO_CW1_Q3).

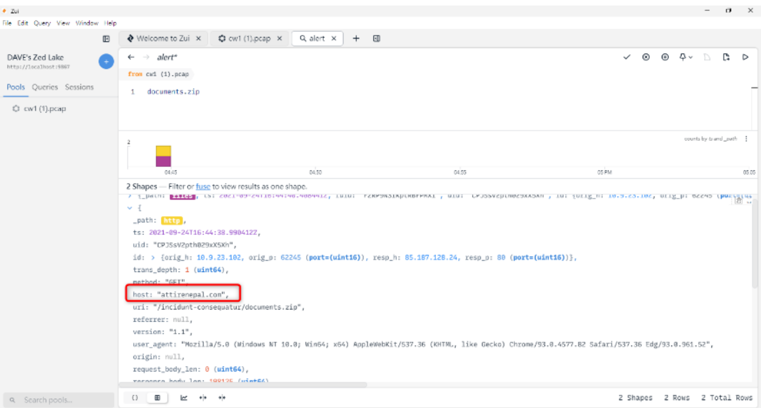


Fig SO_CW1_Q3

To avoid being infected, I just check the name inside the compressed file in terminal (Fig SO_CW1_Q4)

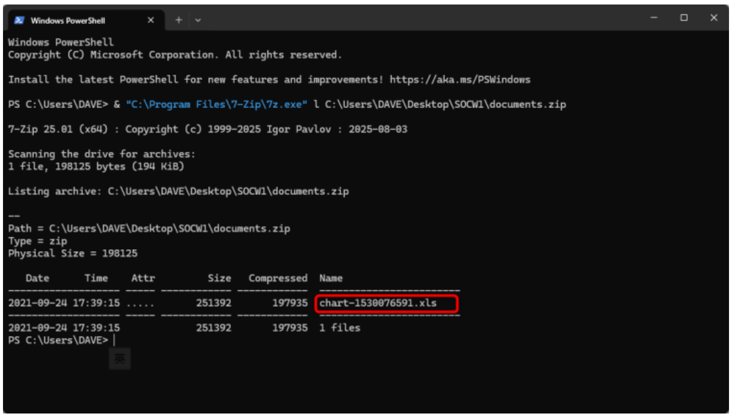


Fig SO_CW1_Q4

Use Zui to find out the traffic of the zip file (Fig SO_CW1_5A). Then, follow TCP stream in Wireshark to see the Server Header (Fig SO_CW1_5B)

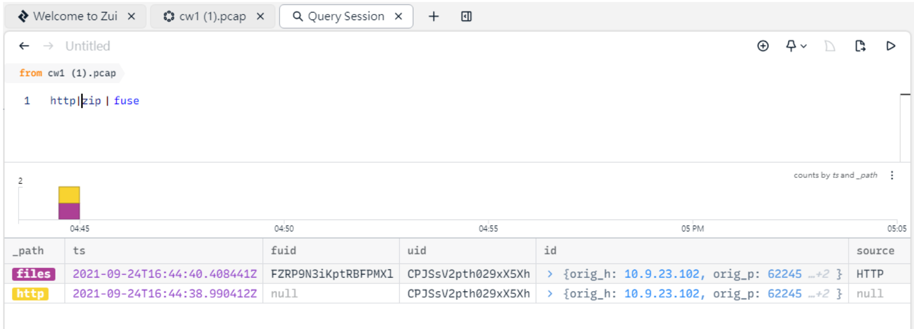


Fig SO_CW1_Q5A

Fig SO_CW1_Q5B

The version of the webserver of the malicious IP is found by follow TCP stream in Wireshark (Fig SO_CW1_Q6)

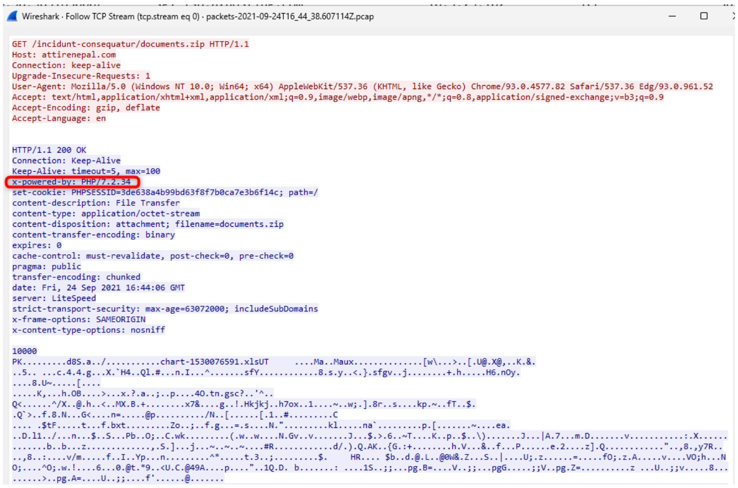


Fig SO_CW1_Q6

The three additional domains involved in downloading malicious files is between 16:45:11 to 16:45:30 (Fig SO_CW1_Q7)

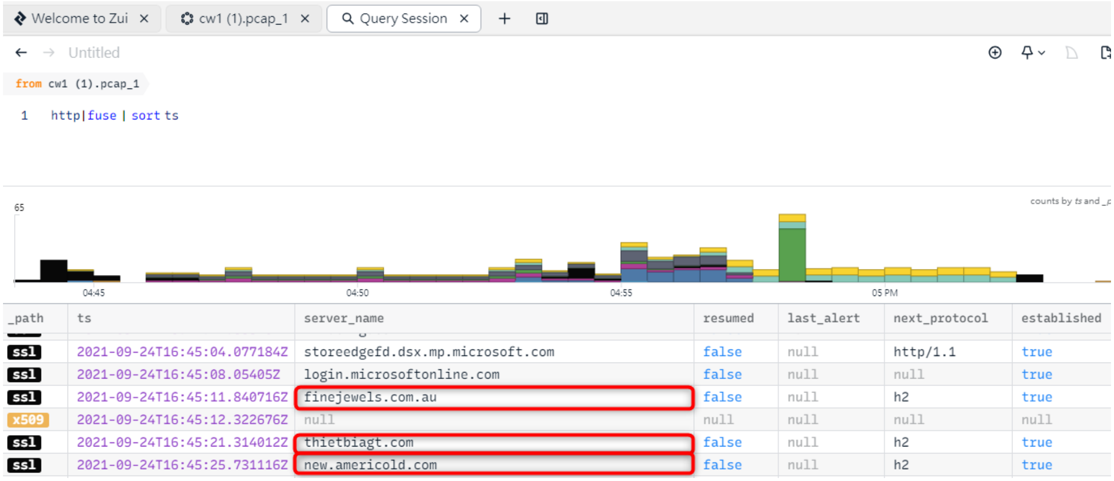


Fig SO_CW1_Q7

The CA issued SSL certificate is shown in Fig SO_CW1_Q8.

Fig SO_CW1_Q8

The post infection traffic was directed to the domain maldivehost.net (Fig SO_CW1_Q13A and 13B). That is 208.91.128.6. and load C2 server. It generate the virus to other infected IP or zombie.

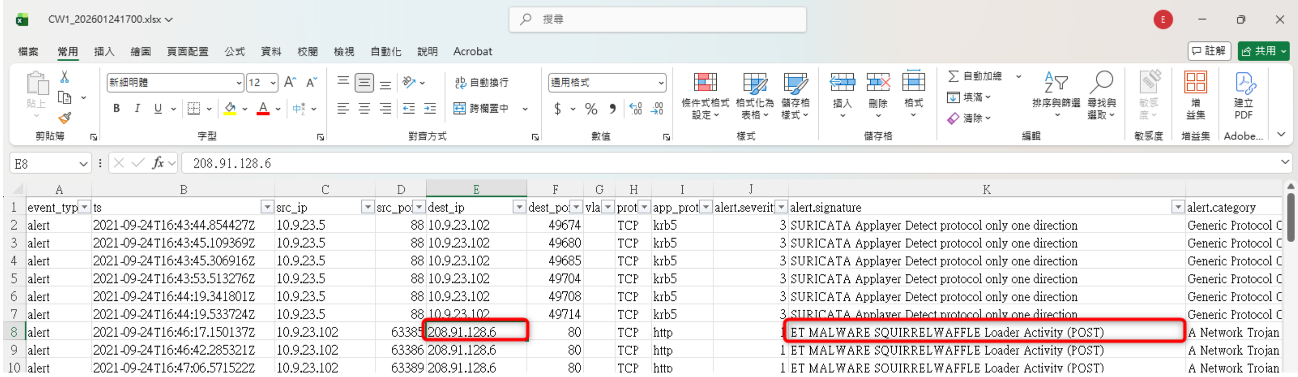


Fig SO_CW1_Q13A

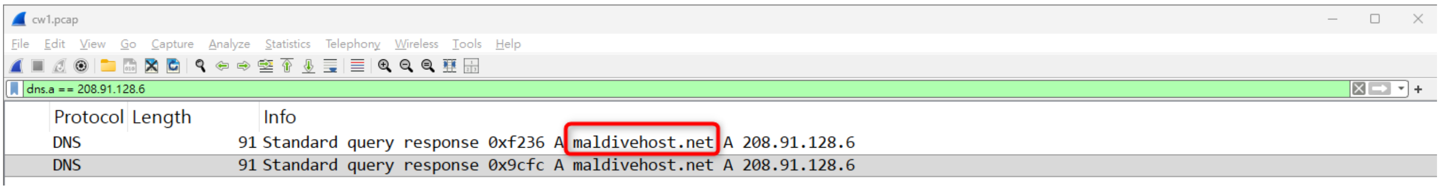


Fig SO_CW1_Q13B

For questions 14 to 16 is about the information about this load C2 server(208.91.128.6) or the packet information that sent to this IP. (Fig SO_CW1_Q14, Fig SO_CW1_Q15, Fig SO_CW1_Q16)

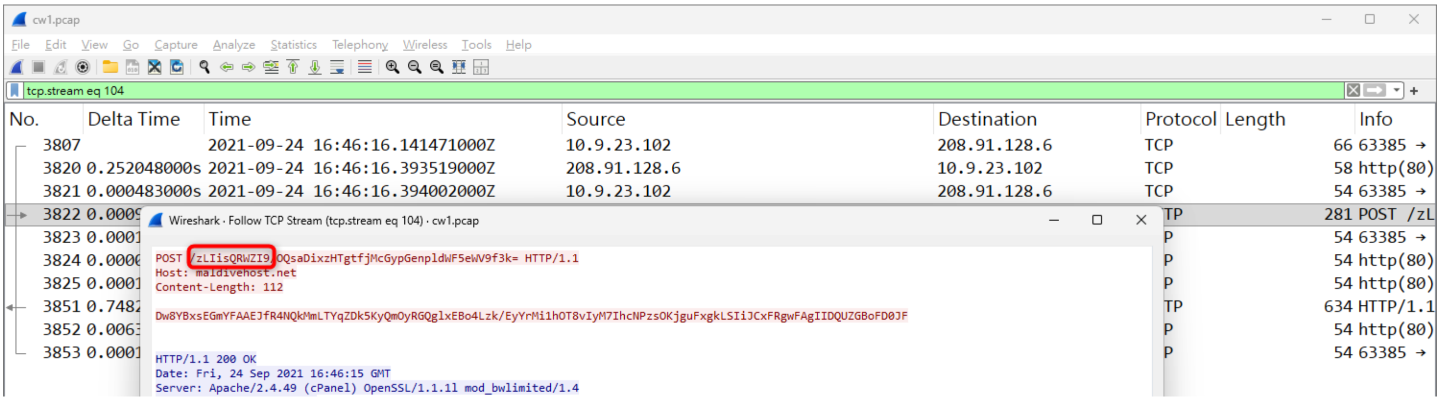


Fig SO_CW1_Q14

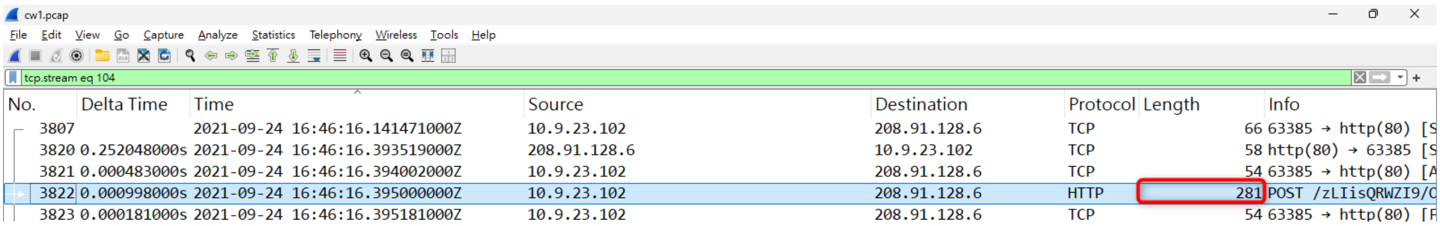


Fig SO_CW1_Q15

Fig SO_CW1_Q16

Phrase 2 in the question set (Q9-12):

To check which two IP are the Cobalt Strike C2 server, I first search the statistics in Wireshark to find the IP list in the descending order of traffic frequency. (Fig SO_CW1_9A) And then, I check the IP on VirusTotal. Then, it is found in community comment that 185.106.96.158 and 185.125.204.174 are cobalt strike (Fig SO_CW1_9B and Fig SO_CW1_9C)

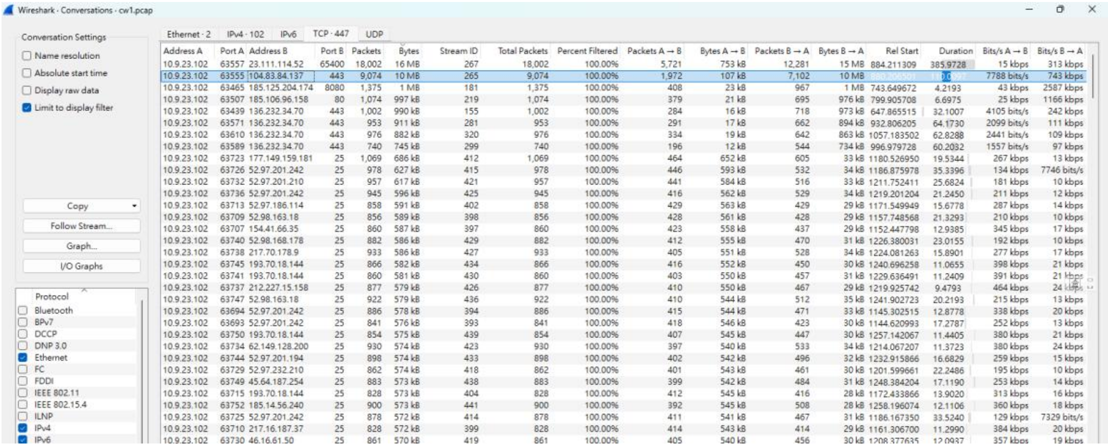
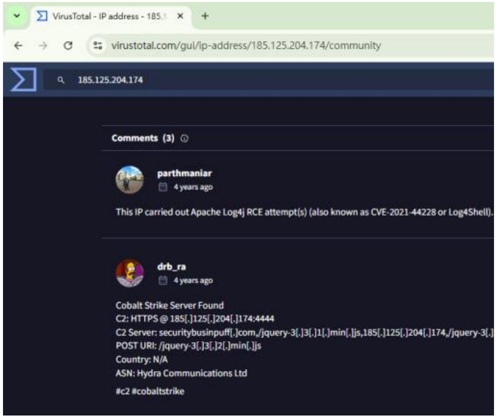


Fig SO_CW1_Q9A



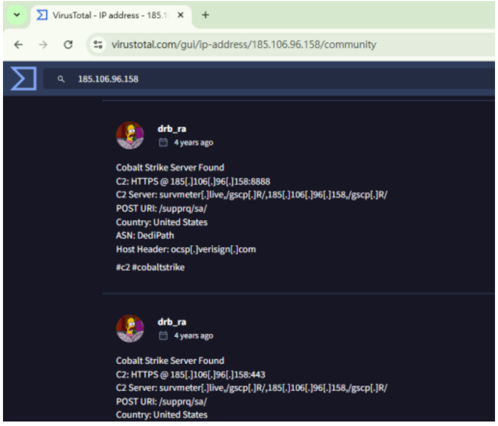


Fig SO_CW1_Q9B

Fig SO_CW1_Q9C

From question 10 to 12 are the information about these Cobalt Strike server. (Fig SO_CW1_Q10, Fig SO_CW10, Q11, SO_CW1_Q12_)

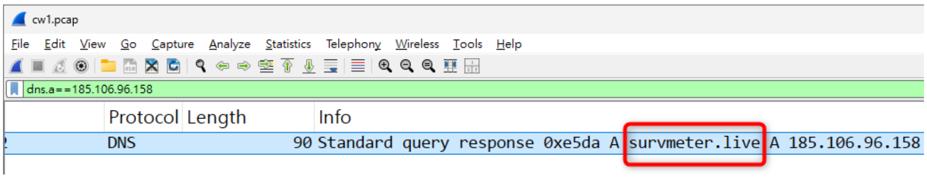
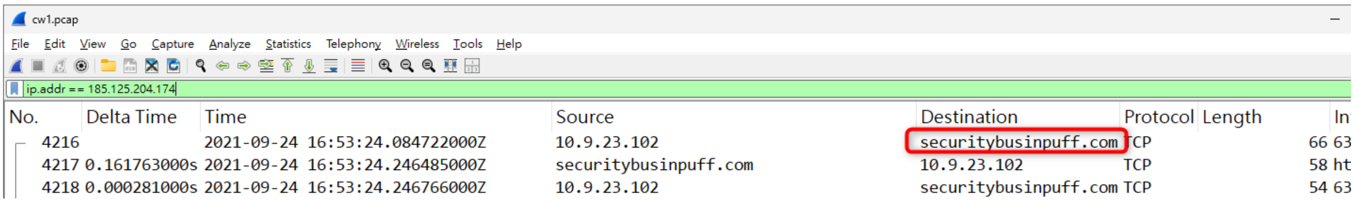


Fig SO_CW1_Q10

Fig SO_CW1_Q11



SO_CW1_Q12_

Phrase 3 in the question set (Q17-18):

The malware check the victim's IP by requesting victim to lookup the external IP in ipify.org (Fig SO_CW1_Q17)

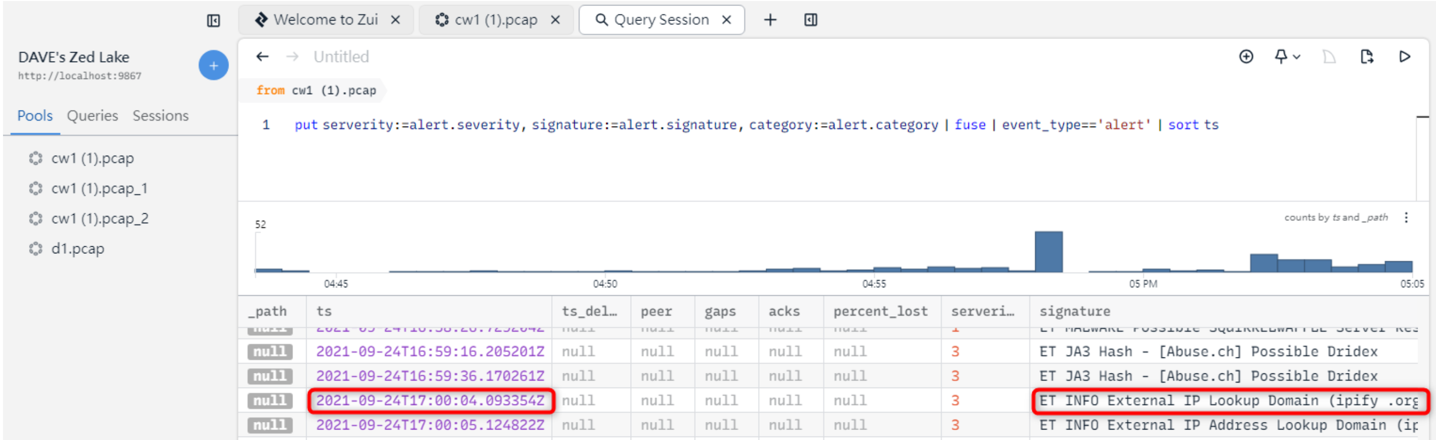


Fig SO_CW1_Q17

And the domain name of previous DNS query is found. (Fig SO_CW1_Q18)

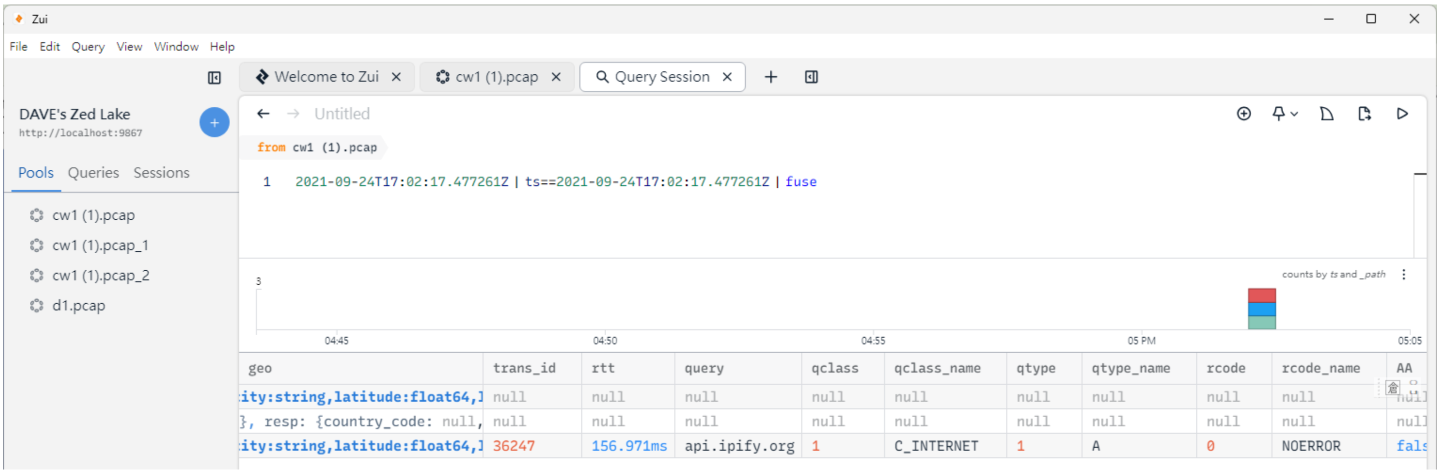


Fig SO_CW1_Q18

Phrase 4 in the question set (Q19-20):

Victims sends spam emails to other computers through port 25 using SMTP protocal. These emails are spam because I search one of the victim's target 93.89.226.88 in Virustotalthe COUPON .... which is the content of the spam email. There is the spelling mistake is to escape from the spam mail filter.

The first email observed are found in Zui as below (Fig SO_CW1_Q19):

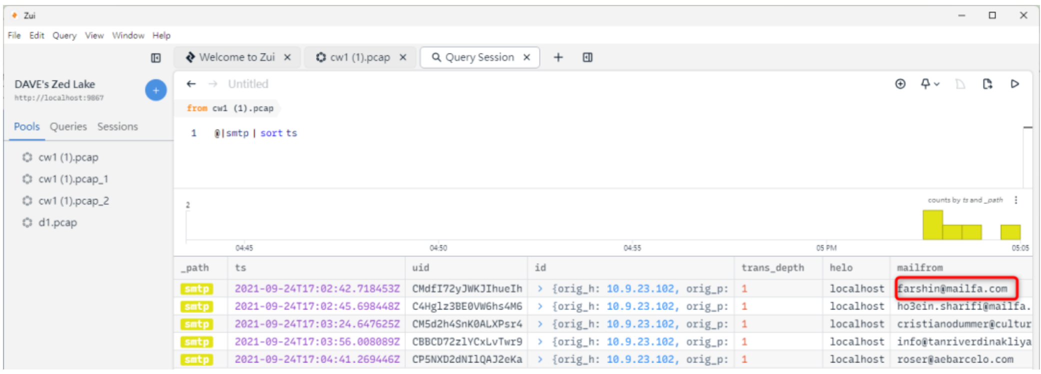


Fig SO_CW1_Q19

After follow TCP stream in Wireshark, the “Password” is found in the CyberChef. (Fig SO_CW1_Q20)

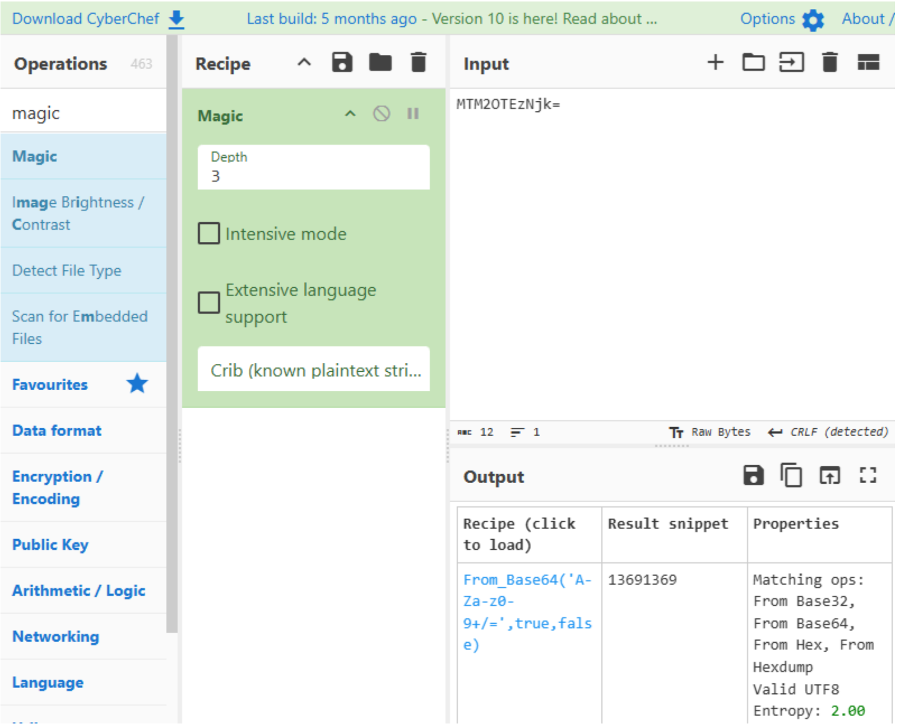


Fig SO_CW1_Q20

(4) Conclusion

To conclude, the victim is totally controlled by the hacker malwares. Therefore, it needs to have Windows reinstalled. To prevent the similar attack in the future, it is suggested that not to open the attached file in the suspicious emails.

(5) References

Github Link : https://github.com/wingftsui/COMP3010HK-CW1
Video evidence is in the above github.